NETWORK DEFENCE PLAN

Prepared by: Varun Chowdary Challagundla

Date: 7 October 2026

Client: Maya's Clothing Shop (small retail business)

Engagement: Network Security Assessment and Remediation Plan

1. ASSESSMENT SUMMARY

Maya's shop runs on a single flat network where the payment tills, customer Wi-Fi, never-updated cameras, customer data and personal devices all share one space with no barriers between them. A compromised device, whether a camera, a guest's phone or an attacker who cracks the three-year-old chalkboard Wi-Fi password, could reach the tills and customer records, and with no logs or monitoring nobody would know. The most urgent priorities are to take back control of the router from its default admin credentials and to segment the payment systems away from customer Wi-Fi. Both fixes use router features she likely already has, so a small number of low-cost, prioritised changes can make this network sustainable and more defensible.

2. NETWORK INVENTORY

Device / system	Category	Holds / does
Payment till x2	Payment	Card transactions, regulated (PCI DSS)
Security cameras x4	IoT	Never updated; vulnerable devices
Back-office laptop	Data	Customer records
Maya's laptop	Personal	Dual use: business and personal
Staff phones x2	Staff	Connected to the shop's Wi-Fi
Smart speaker	IoT	Unmanaged extra device
Network printer	Infrastructure	Shared by everyone on the network
Customer Wi-Fi	Guest	Shares the same network as the tills
ISP router	Infrastructure	Default admin credentials, WPA2

3. PRIORITISED RISKS

CRITICAL

- **Flat network:** Any compromised device can reach the payment tills and customer data. Attackers can move laterally to the valuable target just by getting into the network.
- **Customer Wi-Fi shares the network with the payment tills:** Real money and legal obligations are exposed to anyone who walks in.
- **Default router admin credentials:** Trivial takeover. Whoever controls the router controls every other defence, including any firewall or segmentation settings.

HIGH

- **Weak, shared, public Wi-Fi password:** Unchanged for three years and written on a chalkboard. Everyone who has ever seen it still has access.
- **No monitoring and no logs:** An attack would go unnoticed and could not be investigated afterwards.
- **Uncertain firewall status:** Nobody knows whether a firewall is running or what rules it follows, so there may be no default-deny barrier at all.

MEDIUM

- **Four never-updated IoT cameras:** Known-vulnerable and unsegmented. This is the exact condition the Mirai botnet exploited.
- **Back-office laptop holds customer data with no access control:** No least privilege, so anyone or anything on the network may be able to reach it.
- **Maya's dual-use laptop on the business network:** Home browsing, personal accounts and business access mix on one device, so a compromise of either side exposes the other.

LOW

- **Unmanaged smart speaker:** A low-value device, but still an unmanaged extra on a flat network.
- **Shared printer on the main network:** Reachable by every device, including guests.

4. RECOMMENDED FIXES

Flat network, and customer Wi-Fi sharing with the tills

SEGMENT the network into separate zones, each given only the connectivity it needs (least privilege applied to networks):

- **Payment:** the two tills only, isolated from customer Wi-Fi and from the cameras.
- **Customer / guest Wi-Fi:** internet access only, walled off from everything else (use the router's guest network feature).
- **IoT:** the four cameras, the smart speaker and the printer, on their own segment.
- **Staff and office:** the back-office laptop and staff phones.

Default router credentials

- CHANGE the router admin password from the default to a strong, unique one that is stored in a password manager, not written down in the shop.
- Update the router firmware.
- Confirm that remote administration from the internet is turned off.

Weak, public Wi-Fi password

- Set Wi-Fi to WPA3, or WPA2 as the minimum (never WEP or open), with a long, unique password.
- Keep the staff/office Wi-Fi password private, and give customers only the separate guest network and its own password. Rotate the guest password periodically.
- Remove the chalkboard password.

Uncertain firewall

- Check that the router's built-in firewall is enabled and follows default deny: inbound traffic is blocked unless explicitly allowed.
- Turn on the host-based firewall (Windows Defender Firewall or the macOS equivalent) on both laptops, especially Maya's, which leaves the shop.
- Check that IPv6 is either secured by the router firewall or switched off if unused, so it doesn't become an open door beside protected IPv4.

No monitoring and no logs

- Enable basic logging on the router (connections, admin logins, Wi-Fi events) and make sure the router's clock is time-synced so entries line up.
- Where the router supports it, keep NAT and connection logs and send them to an external location (cloud log service or a separate device) so an attacker cannot simply delete them.

Never-updated IoT cameras

- Move the cameras to the isolated IoT segment so they can't reach the tills or customer data.
- Change their default credentials, install any available firmware updates, and replace models that can no longer be updated.

Customer data on the back-office laptop

- Restrict access to the people who genuinely need it (least privilege), with a separate login per person and no shared accounts.
- Turn on MFA for accounts that touch customer data, and keep the laptop and its software updated.
- Keep the laptop on the staff/office segment, away from guests and IoT devices.

Smart speaker and printer

- Keep them on the IoT segment, or remove the speaker from the business network if it isn't needed.

Beyond the network (low-cost habits)

- Protect the domain registrar account with a strong unique password and MFA. Registrar takeover bypasses every technical defence and lets an attacker redirect the website and email.
- Use hosting and a DNS provider with built-in DDoS protection (for example Shopify, Cloudflare, AWS Route 53 or Google Cloud DNS).
- Brief staff on phishing, since a perfectly working firewall does not stop social engineering.

5. PHASED ACTION PLAN

DO FIRST (critical, highest leverage)

- Change the default router admin credentials and update the firmware.
- Confirm the router firewall is on and set to default deny.
- Segment the payment tills and customer Wi-Fi apart (guest network for customers).

THIS WEEK

- New strong, unique Wi-Fi password for staff/office (WPA3 if supported, WPA2 minimum).
- Put the four IoT cameras on their own isolated segment and change their default credentials.

- Move the printer and smart speaker onto the IoT segment.
- Turn on host firewalls on both laptops.

THIS MONTH

- Set up logging, with time sync and off-device log storage; consider managed monitoring.
- Tidy access control on the back-office laptop and customer data (least privilege, separate accounts, MFA).
- Separate Maya's personal and business use.
- Secure the domain registrar account with MFA and confirm DDoS-protected hosting/DNS.

6. HOW MAYA WILL KNOW IT WORKED

1. **Segmentation test:** A customer device connected to the guest Wi-Fi cannot reach the till network, the cameras, the printer or the back-office laptop.
2. **Credential and Wi-Fi check:** The router admin login no longer accepts the default password, remote admin is off, the Wi-Fi shows WPA3 (or WPA2 at minimum) and the old chalkboard password no longer works.
3. **Visibility check:** Logging is active, the log is being stored off the router, and Maya (or her provider) reviews it on a set schedule.